摘要：

黑客组织以虚假招聘面试为入口，历时数月分三阶段攻破币安系统：先诱导工程师下载含恶意代码的“面试作业”，再借助币安自身内部AI工具横向渗透，最终于10月29日触发恶意脚本，盗走63亿美元，超越Bybit案成史上最大数字资产盗窃案。

加密货币交易所币安（Binance）遭遇史上规模最大的数字资产盗窃案，63亿美元在一次精心策划的多阶段攻击中被窃取。而事件的起点，则是一场专门针对该公司工程师的虚假招聘面试。

据英国《金融时报》和彭博社报道，币安周二（11月3日）发布迄今最详细的调查报告，将此次攻击归因于黑客组织TraderTraitor，并披露攻击者综合运用社会工程学手段、恶意软件及人工智能工具，历时数月完成渗透。币安联席首席执行官Richard Teng表示，**“这不是一次单一错误或单一漏洞，而是一场历经数月精心构建的攻击行动。”**

此次事件已超越今年早些时候Bybit交易所的15亿美元盗窃案，成为数字资产史上最大规模的黑客攻击。尽管案情震惊市场，但市场反应相对克制——比特币在事件曝光后一度下跌逾4%至约76000美元，截至周二已回升至约77600美元。币安表示将自行承担财务损失，并称已基本补足被盗加密资产。

假面试为引，三名工程师相继沦陷

报道称，根据币安调查报告，此次攻击的核心突破口是一场精心设计的虚假招聘流程，历时数月、分阶段完成对币安内部系统的渗透。

今年6月，币安第一名工程师在下载一款被篡改的软件程序时，无意间将自身角色及部分钱包基础设施团队同事的身份暴露给了攻击者。 币安表示，该异常行为虽被系统检测到，涉事设备也随即被更换，但在此之前，相关信息已遭泄露。

同年9月，第二名工程师通过一个求职平台被一名自称某公司项目总监的人联系，随后参与了一场“工作面试”。币安报告显示，对方在面试过程中主动分享个人社交媒体主页，“包括在平台上发布的个人照片和视频，以建立信任感”，币安将此描述为“比以往所见更为高级和欺骗性的社会工程学手段”。

在随后通过社交聊天应用进行的第二轮面试中，另一名自称该虚假公司首席执行官的人要求该工程师下载一份面试作业文件。**这份文件内嵌恶意代码，下载行为未被检测系统拦截，由此成为整个攻击链条中最关键的突破口。**

币安报告对该恶意软件的技术手段作出描述：

> “该恶意软件采用了复杂的混淆与规避技术，包括将合法开发工具组件替换为恶意版本，以执行命令并与攻击者控制的外部服务器建立通信。”

内部AI工具成帮凶，攻击者层层扩大控制范围

据报道，获得第二名工程师的被攻陷笔记本电脑后，攻击者并未就此止步，而是借助币安自身的内部AI工具，进一步横向渗透至其他工程师的设备。

根据报告，攻击者利用该受感染设备及币安内部AI工具，先后控制了第一名工程师和第三名工程师的笔记本电脑。**第一名工程师拥有代码发布权限，这一权限随即被黑客加以利用。**币安报告指出，攻击者通过内部AI工具获取了对部分系统的控制权，但报告未具体说明该工具的名称及被利用的具体方式。

在正式攻击发生前九天，攻击者已悄然渗透至两名与数字钱包业务相关工程师的电脑。**10月29日，即黑客事件当日，攻击者登录第三名工程师的笔记本电脑，“触发一段恶意脚本，发动攻击”，63亿美元由此被盗走。**

市场影响有限，币安着手善后

事件发生后，行业各方迅速采取行动控制损失。据华尔街见闻文章此前写道，稳定币巨头Tether及Circle Internet Group等机构在事件曝光后第一时间冻结了近30亿美元资金，阻止黑客转移。

币安方面，交易所在事件发生后暂停提款近两天，并于当地时间上周日凌晨开始逐步恢复用户提币功能。**币安表示将自行承担全部财务损失，已动用企业自有资金及两只保险基金，接近补足被盗加密资产。** 截至周二，该交易所报告每小时存款已开始超过每小时提款。

在系统层面，币安表示已重建受影响的钱包基础设施和内部AI工具，同时提升安全扫描能力并部署AI驱动的检测系统。与此同时，币安正与美国执法机构展开合作，合作方包括联邦调查局、美国特勤局及司法部。

币安表示将对部分安全措施的具体内容予以保密，“以防止恶意行为者利用相关信息策划未来的攻击”。

风险提示及免责条款

市场有风险，投资需谨慎。本文不构成个人投资建议，也未考虑到个别用户特殊的投资目标、财务状况或需要。用户应考虑本文中的任何意见、观点或结论是否符合其特定状况。据此投资，责任自负。

限时权益申领 * 体验资格每人限申领一次
VIP会员·7天畅读卡 | 大师课·入门串讲
扫码 免费领取

限免

188 收藏

分享到:

写评论

请发表您的评论

表情 图片

发布评论